Relatório de Auditoria de Segurança — Inova CRM AI

Data: 2026-09-01

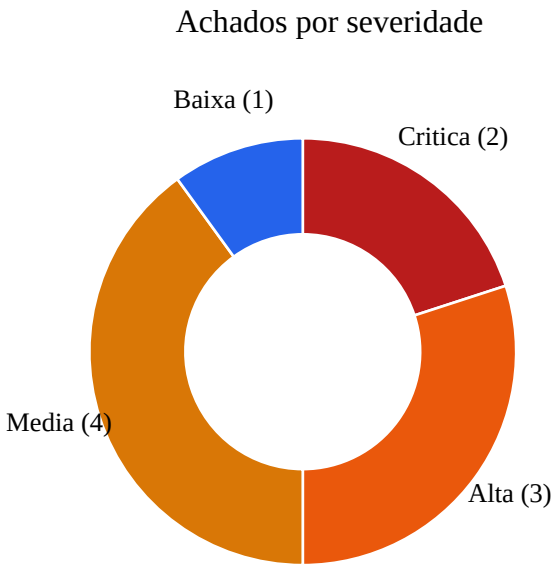
Escopo: backend NestJS/Prisma, frontend Next.js, ai-services FastAPI, workers, docker-compose/CI scripts, histórico git (segredos), busca XSS.

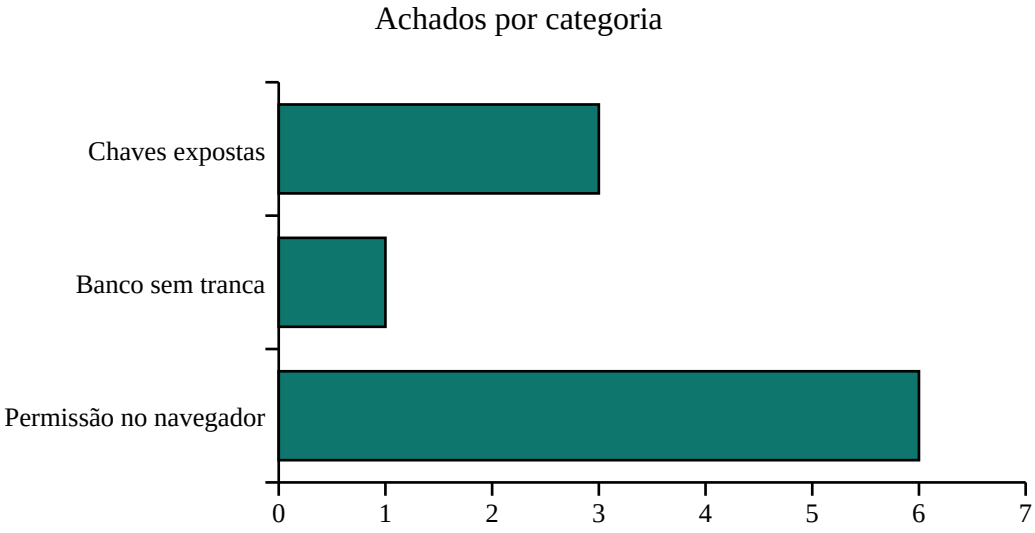
Metodologia / mapeamento à stack:
1) *Banco sem tranca* → TenantGuard + filtro tenantId + RLS Postgres (não Supabase).
2) *Permissão no navegador* → cruzar frontend/lib/navigation.ts e gates UI com @Roles nos controllers NestJS.
3) *IDOR* → todos os *.controller.ts e services findFirst/update/delete por id.
4) *Chaves expostas* → código, compose ${VAR:-default}, seed, git history, NEXT_PUBLIC_*.
5) *XSS* → sinks React/HTML/e-mail; lib de sanitização se aplicável.

Somente achados verificados no código. Ausência de sink XSS foi registrada como ponto forte, não como achado forçado.

1. Resumo executivo

Total de achados acionáveis: **10** — crítica 2, alta 3, média 4, baixa 1. Pontos fortes documentados: 10.





2. Pontos fortes e fracos

2.1 Pontos fortes (evidência)

Isolamento tenant (JWT + TenantGuard + RLS)

TenantGuard exige tenant e rejeita mismatch JWT×header (backend/src/tenancy/tenant.guard.ts:37-43). Prisma set_config + migrations ENABLE/FORCE ROW LEVEL SECURITY em tabelas de domínio; testes em rls.spec.ts.

Lookups por ID com tenantId (anti-IDOR cross-tenant)

Serviços de leads/contacts/opportunities/finance/billing/proposals/contracts/tasks/products/etc. usam findFirst({ where: { id, tenantId } }) — não findUnique só por id.

Mutações privilegiadas com @Roles

Escritas em leads, opportunities, billing payments, config, saas, identity create/update, COQL (ADMIN), reports export, blueprint, etc. declaram @Roles. RolesGuard global no AuthModule.

SaaS / SUPER_ADMIN no servidor

saas.controller.ts exige UserRole.SUPER_ADMIN em todos os handlers — UI AdminSaaSClient não é a única barreira.

JWT_SECRET fail-fast em produção

resolveJwtSecret rejeita ausente/curto/placeholders conhecidos quando NODE_ENV=production (jwt-secret.ts + jwt-secret.spec.ts). Compose API força NODE_ENV=production.

Webhooks inbound com HMAC obrigatório

verifyHmacSignature retorna false se signature ou secret vazios (common/utils.ts:17-18); Chatwoot/n8n webhooks @Public mas autenticam por HMAC.

AI FastAPI Bearer (Spec 029)

ai-services/app/auth.py exige AI_API_TOKEN; em production sem token → 503 fail-closed.

XSS — sem sinks HTML perigosos

Nenhum dangerouslySetInnerHTML/innerHTML/v-html/markdown raw no frontend/backend. React escapa texto; hrefs de atividade do dashboard são paths fixos gerados no server (dashboard.service.ts). Sem templates de e-mail HTML com input do usuário.

Register público desabilitado em produção

auth.service.ts:22-24 exige ALLOW_PUBLIC_REGISTER=true para registrar em production.

Identity bloqueia promoção a SUPER_ADMIN

assertAssignableRole + enum AssignableUserRole (identity.service.ts / user.dto.ts).

2.2 Pontos fracos (riscos centrais)

O padrão dominante é **RBAC incompleto**: (1) @PlatformApi não restringe a API_TOKEN — JWT humano alcança purge LGPD / SLA check-all; (2) GETs sensíveis sem @Roles enquanto a Spec 030 só esconde a UI; (3) secrets de webhook em claro. Em paralelo, histórico git pré-029 e placeholders Evolution reforçam risco de credencial previsível se ops falhar.

3. Achados detalhados

Sev.	Arquivo:linha	Descrição
CRITICA	backend/src/webhook-subscriptions/webhook-subscriptions.controller.ts:28-36	**F-01** — GET de webhook-subscriptions sem @Roles retorna secret em claro
ALTA	backend/src/finance/finance.controller.ts:15-25	**F-02** — Listagem/leitura de invoices sem @Roles (UI /financeiro restrita)
ALTA	backend/src/bulk/bulk.controller.ts:16-31	**F-03** — Jobs/download CSV bulk sem @Roles (UI /bulk restrita)
MEDIA	backend/src/identity/identity.controller.ts:21-24	**F-04** — GET /users/:id sem @Roles (UI /usuarios restrita)
MEDIA	backend/src/prisma/prisma.service.ts:20-22	**F-05** — Extensão Prisma pula set_config quando ALS tenantId está ausente
ALTA	backend/prisma/seed.ts (histórico git d0fdaab):histórico	**F-06** — Senhas reais de ops/seed ainda no histórico git
MEDIA	backend/prisma/seed.ts:10	**F-07** — Default local de senha admin ainda no seed atual
MEDIA	chatwoot/docker-compose.evolution.yml:21,41,68,72	**F-08** — Defaults fracos ${VAR:-change_me_*} no profile Evolution
BAIXA	frontend/lib/navigation.ts vs backend/src/reports/reports.controller.ts:17 / 16-17	**F-09** — Dessincronia RBAC relatórios (MANAGER na UI, não na API)
CRITICA	backend/src/lgpd/lgpd.controller.ts + opportunities.controller.ts + guards:12-19 / 53-60 / tenant.guard:18-24 / roles.guard:24-26	**F-10** — @PlatformApi aceita qualquer JWT (não só API_TOKEN)

F-01 — [CRITICA] GET de webhook-subscriptions sem @Roles retorna secret em claro

Categoria: Permissão no navegador

Local: backend/src/webhook-subscriptions/webhook-subscriptions.controller.ts:28-36

Descrição: findAll/findOne não têm @Roles; RolesGuard libera qualquer JWT autenticado. O service devolve o model completo incluindo o campo secret (HMAC).

Explorabilidade: VIEWER/SALES autenticados chamam GET /api/v1/webhook-subscriptions e obtêm segredos de assinatura outbound, podendo forjar entregas HMAC.

```
@Get()
findAll(@TenantId() tenantId: string) {
  return this.service.findAll(tenantId);
}
// service: findMany → WebhookSubscription[] com .secret
```

Correção: Adicionar @Roles(ADMIN, MANAGER) nos GETs; nunca serializar secret em listagens (mascarar ou omitir); endpoint dedicado de rotação.

F-02 — [ALTA] Listagem/leitura de invoices sem @Roles (UI /financeiro restrita)

Categoria: Permissão no navegador

Local: backend/src/finance/finance.controller.ts:15-25

Descrição: Nav frontend limita /financeiro a ADMIN_MANAGER_ROLES, mas GET /invoices e GET /invoices/:id não declaram @Roles.

Explorabilidade: Qualquer papel autenticado (ex.: VIEWER) ignora o AppShell e consulta a API diretamente, lendo dados financeiros do tenant.

```
@Get()
findAll(@TenantId() tenantId: string) {
  return this.financeService.findAll(tenantId);
}
```

Correção: Alinhar @Roles(ADMIN, MANAGER) aos GETs como já feito em payments (billing).

F-03 — [ALTA] Jobs/download CSV bulk sem @Roles (UI /bulk restrita)

Categoria: Permissão no navegador

Local: backend/src/bulk/bulk.controller.ts:16-31

Descrição: POST export/import exigem ADMIN/MANAGER, mas GET jobs, GET jobs/:id e download CSV não têm @Roles. Nav restringe /bulk a ADMIN_MANAGER.

Explorabilidade: Papel baixo lista jobs e baixa CSV de export se souber/enumerar o id (tenant-scoped, mas ainda privilegiado).

```
@Get('jobs/:id/download')
@Header('Content-Type', 'text/csv')
async download(...) {
  return this.bulkService.getExportCsv(tenantId, id);
}
```

Correção: Aplicar @Roles(ADMIN, MANAGER) em todos os GETs de /bulk.

F-04 — [MEDIA] GET /users/:id sem @Roles (UI /usuarios restrita)

Categoria: Permissão no navegador

Local: backend/src/identity/identity.controller.ts:21-24

Descrição: listagem exige ADMIN/MANAGER; findOne por id não. passwordHash é omitido no service, mas email/name/role vazam.

Explorabilidade: VIEWER obtém PII de qualquer usuário do tenant por ID.

```
@Get(':id')
findOne(@TenantId() tenantId: string, @Param('id') id: string) {
  return this.identityService.findOne(tenantId, id);
}
```

Correção: @Roles(ADMIN, MANAGER) em findOne, ou restringir a self (sub === id).

F-05 — [MEDIA] Extensão Prisma pula set_config quando ALS tenantId está ausente

Categoria: Banco sem tranca

Local: backend/src/prisma/prisma.service.ts:20-22

Descrição: Se getRequestTenantId() é undefined, a query vai ao baseClient sem set_config('app.tenant_id'). Defesa depende de FORCE RLS + filtro app.

Explorabilidade: Com role DB BYPASSRLS/superuser, queries sem ALS não recebem RLS. Compose recomenda crm_app sem bypass — explorável se DATABASE_URL errado.

```
if (!tenantId) {
  return (baseClient as unknown as DelegateMap)[key][operation](args);
}
```

Correção: Falhar fechado se tenant ausente em models de domínio; ou sempre set_config para valor sentinela que não casa com nenhum tenant_id.

F-06 — [ALTA] Senhas reais de ops/seed ainda no histórico git

Categoria: Chaves expostas

Local: backend/prisma/seed.ts (histórico git d0fdaab):histórico

Descrição: Antes do scrub Spec 029 (878a92f), commits como cdd215c/e9f90a8/d0fdaab versionaram literais de senha (ex.: InovaDemo@2026 e outras usadas em scripts ops). Removidas do HEAD, mas recuperáveis via git log -S / clone completo.

Explorabilidade: Quem tem o repositório recupera as literais e tenta em VPS/demo se não houve rotação após o scrub.

```
# histórico (pré-878a92f)
SEED_ADMIN_PASSWORD ?? 'InovaDemo@2026'
# + literais em scripts de login/demo (scrubbed no HEAD)
```

Correção: Rotacionar todas as senhas/tokens que coincidam com o histórico; confirmar .credentials-operator.txt no .gitignore; rewrite só se política exigir.

F-07 — [MEDIA] Default local de senha admin ainda no seed atual

Categoria: Chaves expostas

Local: backend/prisma/seed.ts:10

Descrição: Fallback ChangeMeLocalOnly@2026! se SEED_ADMIN_PASSWORD ausente.

Explorabilidade: Seed em ambiente sem env aplica senha previsível; seed ainda faz console.log da senha.

```
const ADMIN_PASSWORD = process.env.SEED_ADMIN_PASSWORD ?? 'ChangeMeLocalOnly@2026!';
```

Correção: Exigir SEED_ADMIN_PASSWORD (throw se ausente) fora de NODE_ENV=test; não logar senha.

F-08 — [MEDIA] Defaults fracos ${VAR:-change_me_*} no profile Evolution

Categoria: Chaves expostas

Local: chatwoot/docker-compose.evolution.yml:21,41,68,72

Descrição: Postgres/Redis/API key Evolution usam placeholders se env não sobrescrever. Sem validação de startup que rejeite change_me_*.

Explorabilidade: Subir profile whatsapp-evolution sem .env deixa credenciais públicas conhecidas.

```
POSTGRES_PASSWORD: ${EVOLUTION_POSTGRES_PASSWORD:-change_me_evolution_pg}
AUTHENTICATION_API_KEY: ${EVOLUTION_API_KEY:-change_me_evolution_api_key}
```

Correção: Remover defaults; fail se placeholder; checklist ops obrigatório.

F-09 — [BAIXA] Dessincronia RBAC relatórios (MANAGER na UI, não na API)

Categoria: Permissão no navegador

Local: frontend/lib/navigation.ts vs backend/src/reports/reports.controller.ts:17 / 16-17

Descrição: REPORTS_ROLES inclui MANAGER no frontend; API @Roles apenas ADMIN e SALES. Não é escalação (UI mostra, API 403), mas indica gate só no cliente como fonte de verdade incompleta.

Explorabilidade: Operadores MANAGER veem menu e falham na API; risco de 'corrigir' só o frontend.

```
REPORTS_ROLES = [..., 'MANAGER', 'SALES']
@Roles(UserRole.ADMIN, UserRole.SALES)
```

Correção: Unificar papéis (incluir MANAGER na API ou remover da nav).

F-10 — [CRITICA] @PlatformApi aceita qualquer JWT (não só API_TOKEN)

Categoria: Permissão no navegador

Local: backend/src/lgpd/lgpd.controller.ts + opportunities.controller.ts + guards:12-19 / 53-60 / tenant.guard:18-24 / roles.guard:24-26

Descrição: POST /lgpd/purge e POST /opportunities/sla/check-all usam @PlatformApi() sem @Roles. TenantGuard ignora platform routes; RolesGuard libera sem @Roles; JwtAuthGuard só especializa API_TOKEN — JWT humano cai no Passport e passa.

Explorabilidade: Qualquer usuário autenticado (ex. VIEWER) pode disparar purge LGPD cross-tenant ou SLA check-all, sem API_TOKEN.

```
@Post('purge')
@PlatformApi()
purge() { return this.lgpdService.purgeExpired(); }
// TenantGuard: if (isPlatformApi) return true;
// RolesGuard: if (!requiredRoles) return true;
```

Correção: JwtAuthGuard: em @PlatformApi exigir Bearer === API_TOKEN (rejeitar JWT humano); opcional @Roles(SUPER_ADMIN) como defesa extra.

4. Recomendações priorizadas

P1. Restringir @PlatformApi a Bearer API_TOKEN apenas (lgpd/purge + sla/check-all).

P1. Bloquear GET webhook-subscriptions e deixar de retornar secret; rotacionar secrets existentes.

P1. Aplicar @Roles alinhados à Spec 030 em GET /invoices*, GET /bulk/jobs* e download CSV.

P2. Restringir GET /users/:id; unificar REPORTS_ROLES com @Roles da API.

P2. Rotacionar senhas/tokens do histórico git pré-Spec 029; SEED_ADMIN_PASSWORD obrigatório.

P2. Remover defaults change_me_* do compose Evolution ou fail-closed no boot.

P3. Falhar fechado na extensão Prisma sem ALS tenant; auditoria periódica de handlers sem @Roles.

5. ISSUES PARA O GITHUB

Copie cada bloco delimitado para uma issue. Achados relacionados de RBAC GET permanecem separados por recurso (segredo vs financeiro vs bulk) para facilitar revisão.

````
--- ISSUE F-01 ---
# [Segurança] GET de webhook-subscriptions sem @Roles retorna secret em claro

**Labels sugeridas:** `security, severity:critica`

## Problema
findAll/findOne não têm @Roles; RolesGuard libera qualquer JWT autenticado. O service devolve o model completo incluindo o

## Por que é explorável
VIEWER/SALES autenticados chamam GET /api/v1/webhook-subscriptions e obtêm segredos de assinatura outbound, podendo forjar

## Evidência
`backend/src/webhook-subscriptions/webhook-subscriptions.controller.ts:28-36`

```
@Get()
findAll(@TenantId() tenantId: string) {
  return this.service.findAll(tenantId);
}
// service: findMany → WebhookSubscription[] com .secret
```

## Impacto
Vazamento de segredo de assinatura + possível abuso de webhooks do tenant.

## Sugestão de correção
Adicionar @Roles(ADMIN, MANAGER) nos GETs; nunca serializar secret em listagens (mascarar ou omitir); endpoint dedicado de

## Critérios de aceite
- [ ] GET /webhook-subscriptions com JWT VIEWER → 403
- [ ] Resposta de listagem não contém o secret em claro
- [ ] Teste e2e/unit cobrindo o 403
--- FIM ISSUE F-01 ---


--- ISSUE F-02 ---
# [Segurança] Listagem/leitura de invoices sem @Roles (UI /financeiro restrita)

**Labels sugeridas:** `security, severity:alta`

## Problema
Nav frontend limita /financeiro a ADMIN_MANAGER_ROLES, mas GET /invoices e GET /invoices/:id não declaram @Roles.

## Por que é explorável
Qualquer papel autenticado (ex.: VIEWER) ignora o AppShell e consulta a API diretamente, lendo dados financeiros do tenant.

## Evidência
`backend/src/finance/finance.controller.ts:15-25`

```
@Get()
findAll(@TenantId() tenantId: string) {
  return this.financeService.findAll(tenantId);
}
```

## Impacto
Quebra de RBAC financeiro; exposição de faturas.

## Sugestão de correção
Alinhar @Roles(ADMIN, MANAGER) aos GETs como já feito em payments (billing).

## Critérios de aceite
- [ ] GET /invoices com JWT VIEWER → 403
- [ ] GET /invoices com JWT ADMIN → 200
- [ ] Teste de contrato/RBAC
--- FIM ISSUE F-02 ---
````

````
--- ISSUE F-03 ---
# [Segurança] Jobs/download CSV bulk sem @Roles (UI /bulk restrita)

**Labels sugeridas:** `security, severity:alta`

## Problema
POST export/import exigem ADMIN/MANAGER, mas GET jobs, GET jobs/:id e download CSV não têm @Roles. Nav restringe /bulk a ADM

## Por que é explorável
Papel baixo lista jobs e baixa CSV de export se souber/enumerar o id (tenant-scoped, mas ainda privilegiado).

## Evidência
`backend/src/bulk/bulk.controller.ts:16-31`

```
@Get('jobs/:id/download')
@Header('Content-Type', 'text/csv')
async download(...) {
  return this.bulkService.getExportCsv(tenantId, id);
}
```

## Impacto
Exfiltração de exportações CRM (leads/contatos/empresas).

## Sugestão de correção
Aplicar @Roles(ADMIN, MANAGER) em todos os GETs de /bulk.

## Critérios de aceite
- [ ] GET /bulk/jobs/:id/download com VIEWER → 403
- [ ] ADMIN/MANAGER → 200 quando job existir
--- FIM ISSUE F-03 ---


--- ISSUE F-04 ---
# [Segurança] GET /users/:id sem @Roles (UI /usuarios restrita)

**Labels sugeridas:** `security, severity:media`

## Problema
listagem exige ADMIN/MANAGER; findOne por id não. passwordHash é omitido no service, mas email/name/role vazam.

## Por que é explorável
VIEWER obtém PII de qualquer usuário do tenant por ID.

## Evidência
`backend/src/identity/identity.controller.ts:21-24`

```
@Get(':id')
findOne(@TenantId() tenantId: string, @Param('id') id: string) {
  return this.identityService.findOne(tenantId, id);
}
```

## Impacto
Enumeração de usuários e papéis dentro do tenant.

## Sugestão de correção
@Roles(ADMIN, MANAGER) em findOne, ou restringir a self (sub === id).

## Critérios de aceite
- [ ] GET /users/:otherId com VIEWER → 403
- [ ] ADMIN → 200
--- FIM ISSUE F-04 ---


--- ISSUE F-05 ---
# [Segurança] Extensão Prisma pula set_config quando ALS tenantId está ausente

**Labels sugeridas:** `security, severity:media`

## Problema
Se getRequestTenantId() é undefined, a query vai ao baseClient sem set_config('app.tenant_id'). Defesa depende de FORCE RLS

## Por que é explorável
````

Com role DB BYPASSRLS/superuser, queries sem ALS não recebem RLS. Compose recomenda crm_app sem bypass — explorável se DATAB

Evidência
`backend/src/prisma/prisma.service.ts:20-22`

```
if (!tenantId) {
  return (baseClient as unknown as DelegateMap)[key][operation](args);
}
```

Impacto
Perda da camada RLS em caminhos sem interceptor/ALS (misconfig).

Sugestão de correção
Falhar fechado se tenant ausente em models de domínio; ou sempre set_config para valor sentinela que não casa com nenhum ten

Critérios de aceite
- [ ] Operação de domínio sem ALS falha em teste
- [ ] Documentar proibição de superuser na API
--- FIM ISSUE F-05 ---

--- ISSUE F-06 ---
[Segurança] Senhas reais de ops/seed ainda no histórico git

Labels sugeridas: `security, severity:alta`

Problema
Antes do scrub Spec 029 (878a92f), commits como cdd215c/e9f90a8/d0fdaab versionaram literais de senha (ex.: InovaDemo@2026 e

Por que é explorável
Quem tem o repositório recupera as literais e tenta em VPS/demo se não houve rotação após o scrub.

Evidência
`backend/prisma/seed.ts (histórico git d0fdaab):histórico`

```
# histórico (pré-878a92f)
SEED_ADMIN_PASSWORD ?? 'InovaDemo@2026'
# + literais em scripts de login/demo (scrubbed no HEAD)
```

Impacto
Compromisso de contas admin/demo se credenciais históricas ainda válidas.

Sugestão de correção
Rotacionar todas as senhas/tokens que coincidam com o histórico; confirmar .credentials-operator.txt no .gitignore; rewrite

Critérios de aceite
- [ ] Credenciais históricas não autenticam em nenhum ambiente
- [ ] .credentials-operator.txt ignorado pelo git
--- FIM ISSUE F-06 ---

--- ISSUE F-07 ---
[Segurança] Default local de senha admin ainda no seed atual

Labels sugeridas: `security, severity:media`

Problema
Fallback ChangeMeLocalOnly@2026! se SEED_ADMIN_PASSWORD ausente.

Por que é explorável
Seed em ambiente sem env aplica senha previsível; seed ainda faz console.log da senha.

Evidência
`backend/prisma/seed.ts:10`

```
const ADMIN_PASSWORD = process.env.SEED_ADMIN_PASSWORD ?? 'ChangeMeLocalOnly@2026!';
```

Impacto
Credencial previsível pós-seed.

````
## Sugestão de correção
Exigir SEED_ADMIN_PASSWORD (throw se ausente) fora de NODE_ENV=test; não logar senha.

## Critérios de aceite
- [ ] Seed sem env em production-like falha
- [ ] Logs não imprimem a senha
--- FIM ISSUE F-07 ---


--- ISSUE F-08 ---
# [Segurança] Defaults fracos ${VAR:-change_me_*} no profile Evolution

**Labels sugeridas:** `security, severity:media`

## Problema
Postgres/Redis/API key Evolution usam placeholders se env não sobrescrever. Sem validação de startup que rejeite change_me_

## Por que é explorável
Subir profile whatsapp-evolution sem .env deixa credenciais públicas conhecidas.

## Evidência
`chatwoot/docker-compose.evolution.yml:21,41,68,72`

```
POSTGRES_PASSWORD: ${EVOLUTION_POSTGRES_PASSWORD:-change_me_evolution_pg}
AUTHENTICATION_API_KEY: ${EVOLUTION_API_KEY:-change_me_evolution_api_key}
```

## Impacto
Acesso ao stack Evolution (bind 127.0.0.1:9416 mitiga exposição remota).

## Sugestão de correção
Remover defaults; fail se placeholder; checklist ops obrigatório.

## Critérios de aceite
- [ ] Compose sem env falha health/auth
- [ ] Documentação exige openssl rand
--- FIM ISSUE F-08 ---


--- ISSUE F-09 ---
# [Segurança] Dessincronia RBAC relatórios (MANAGER na UI, não na API)

**Labels sugeridas:** `security, severity:baixa`

## Problema
REPORTS_ROLES inclui MANAGER no frontend; API @Roles apenas ADMIN e SALES. Não é escalação (UI mostra, API 403), mas indica

## Por que é explorável
Operadores MANAGER veem menu e falham na API; risco de 'corrigir' só o frontend.

## Evidência
`frontend/lib/navigation.ts vs backend/src/reports/reports.controller.ts:17 / 16-17`

```
REPORTS_ROLES = [..., 'MANAGER', 'SALES']
@Roles(UserRole.ADMIN, UserRole.SALES)
```

## Impacto
Confusão operacional; regressão futura se só a UI for alterada.

## Sugestão de correção
Unificar papéis (incluir MANAGER na API ou remover da nav).

## Critérios de aceite
- [ ] Nav e @Roles idênticos para /relatorios
- [ ] Teste navigation + API
--- FIM ISSUE F-09 ---


--- ISSUE F-10 ---
# [Segurança] @PlatformApi aceita qualquer JWT (não só API_TOKEN)

**Labels sugeridas:** `security, severity:critica`
````

Problema
POST /lgpd/purge e POST /opportunities/sla/check-all usam @PlatformApi() sem @Roles. TenantGuard ignora platform routes; Ro

Por que é explorável
Qualquer usuário autenticado (ex. VIEWER) pode disparar purge LGPD cross-tenant ou SLA check-all, sem API_TOKEN.

Evidência
`backend/src/lgpd/lgpd.controller.ts + opportunities.controller.ts + guards:12-19 / 53-60 / tenant.guard:18-24 / roles.guard

```
@Post('purge')
@PlatformApi()
purge() { return this.lgpdService.purgeExpired(); }
// TenantGuard: if (isPlatformApi) return true;
// RolesGuard: if (!requiredRoles) return true;
```

Impacto
Destruição/alteração platform-wide; abuso de cron privilegiado.

Sugestão de correção
JwtAuthGuard: em @PlatformApi exigir Bearer === API_TOKEN (rejeitar JWT humano); opcional @Roles(SUPER_ADMIN) como defesa ex

Critérios de aceite
- [ ] POST /lgpd/purge com JWT usuário → 401/403
- [ ] POST /lgpd/purge com Bearer API_TOKEN → 200
- [ ] Idem para /opportunities/sla/check-all
--- FIM ISSUE F-10 ---